Cyberdyne Systems

Startup Security GRC Policy Pack

Prepared by: Aditi Rajendra Katare
Issue date: September 2026
Version: 1.0
Scenario: Fictional 50-person SaaS startup

DRAFT FOR PORTFOLIO REVIEW - NOT AN APPROVED CORPORATE POLICY

Cyberdyne Systems is fictional. This pack is a policy-design exercise. It does not represent actual approval, implementation, audit, certification, or compliance. Replace assumptions, confirm applicable law and contract requirements, and obtain appropriate approval before any operational use.

Contents

1. Acceptable Use Policy
2. Identity, Password & Authentication Standard
3. Access Control & Joiner-Mover-Leaver Policy
4. Data Classification & Handling Policy
5. Security Incident Reporting & Response Policy
6. Appendix A - Framework References and Interpretation
7. Appendix B - Governance and Implementation Companion
8. Appendix C - Portfolio Disclaimer

Executive Summary

This pack defines a proposed baseline of governance and security expectations for a small SaaS startup using Google Workspace, Slack, GitHub, AWS, and employee laptops. It contains five connected policies/standards, plus an implementation companion repository with control mapping, a risk register, evidence register, audit test plan, RACI, rollout roadmap, and reusable templates.

The design emphasises least privilege, stronger authentication for privileged accounts, data handling by sensitivity, prompt incident reporting, temporary and approved exceptions, and testable evidence. The policy text is written so that roles, time targets, and review cadences can be validated during a real implementation rather than left as broad aspirations.

Document Control

Organisation: Cyberdyne Systems (fictional case study)
Author: Aditi Rajendra Katare
Issue date/version: September 2026 / 1.0
Status: Draft; simulated executive approval required
Intended audience: Executive sponsor, GRC, IT, engineering/system owners, People Ops, data owners
Review cycle: Annual minimum; earlier review after a material incident, control failure, or major technology/business change
Intended use: Educational portfolio and policy-design demonstration only

Acceptable Use Policy

Policy ID: CS-GRC-POL-01
Owner: GRC Lead (simulated role)
Applies to: Employees, contractors, interns, and approved third parties
Issue date: September 2026
Version/status: 1.0 / Portfolio draft; simulated approval required
Review cadence: At least annually and after a material incident or technology change
Related documents: Identity & Authentication Standard; Access Control Policy; Data Classification & Handling Policy; Incident Reporting & Response Policy

Portfolio status: This is a proposed policy for a fictional company. It has not been approved, implemented, or tested in a real Cyberdyne Systems environment. It must be reviewed against applicable law, contracts, and actual business requirements before operational use.

1. Purpose

Set clear, risk-based rules for the responsible use of Cyberdyne Systems information, systems, networks, cloud services, collaboration tools, and endpoint devices. The goal is to reduce preventable security incidents while enabling legitimate work.

2. Scope

This policy applies to all people who access Cyberdyne Systems systems or information, and to all company-managed or company-authorised devices, identities, applications, networks, repositories, cloud accounts, and storage locations. The assumed environment for this portfolio scenario is a 50-person SaaS startup using Google Workspace, Slack, GitHub, AWS, and employee laptops.

3. Policy requirements

3.1 Authorised use and accountability

- Use company accounts and services for authorised business purposes. Limited personal use is permitted only when lawful, reasonable, does not disrupt work, and does not create material cost, security, or reputational risk.
- Protect company credentials, customer information, source code, infrastructure details, and business records from unauthorised access or disclosure.
- Complete assigned security awareness training and acknowledge this policy at onboarding and after material revisions.
- Follow the stricter requirement where this policy conflicts with a contract, an approved security standard, or applicable law. Escalate uncertainty to the GRC Lead rather than guessing.

3.2 Devices and endpoint security

- Use company-managed laptops for company data and privileged work unless an exception has been approved in writing.
- Keep operating systems, browsers, endpoint protection, and business applications supported and updated. As an operational target, remediate actively exploited or critical vulnerabilities within 72 hours where feasible, other critical vulnerabilities within 7 calendar days, high-risk vulnerabilities within 14 calendar days, and routine updates within 30 calendar days. The IT Administrator must document risk-based deviations and compensating measures.

- Enable full-disk encryption, automatic screen lock after no more than 10 minutes of inactivity, and supported endpoint protection on company-managed laptops.
- Lock the screen when leaving a device unattended. Do not disable security agents, disk encryption, logging, device management, or endpoint controls without written authorisation.
- Report lost, stolen, tampered-with, or unexpectedly accessed devices immediately through the incident reporting process.

3.3 Internet, email, and collaboration tools

- Treat unexpected attachments, login prompts, QR codes, file-sharing invitations, OAuth permission requests, and urgent payment or credential requests as potential phishing until verified.
- Do not use personal email, personal cloud storage, consumer messaging accounts, or unapproved file-transfer services to store or transmit company information.
- Share files through approved company services with named recipients, least-privilege permissions, and expiry dates where supported. Avoid public links; use them only with documented approval and a time-bound business justification.
- Do not send passwords, API keys, private keys, recovery codes, session cookies, or other secrets in Slack messages, tickets, email, source code, or documents. Use approved secret-management channels.

3.4 Software, source code, and cloud services

- Install software only from trusted sources and only where permitted by the device-management and software-approval process.
- Use approved repositories and organisation-managed accounts for source code. Do not publish proprietary source code, customer data, secrets, internal architecture, or vulnerability details in public repositories without explicit authorisation.
- Do not create personal cloud accounts, shadow IT services, personal access tokens, cloud access keys, integrations, bots, or OAuth applications for business use without approval from the system owner or IT Administrator.
- Never disable branch protection, required reviews, logging, MFA, or cloud security controls to bypass a workflow. Raise a change request when a control blocks a legitimate task.
- Use production environments only for assigned duties. Production data must not be copied to local test systems or development environments unless the data owner approves an appropriate minimisation or masking plan.

3.5 AI tools and external services

- Do not submit Confidential or Restricted information, customer data, source code, credentials, security findings, or non-public business information to public AI assistants or external services unless the service has been approved for that data class and the data owner has authorised the use.
- Verify generated content before using it for security, legal, customer, or operational decisions. AI output does not replace a required human review.
- Do not use company resources for unlawful activity, harassment, unauthorised surveillance, cryptocurrency mining, testing systems without authorisation, or attempts to evade monitoring or access restrictions.

3.6 Remote work and travel

- Use trusted networks. Avoid conducting privileged administration over public Wi-Fi unless a company-approved secure connection is used.
- Prevent shoulder-surfing and unauthorised viewing of screens or printed materials. Keep devices in personal possession while travelling and do not leave them unattended in vehicles or public spaces.
- Report border searches, device seizure, suspected tampering, or unusual authentication prompts to IT and the GRC Lead promptly where lawful and safe to do so.
- Personal devices may access company resources only through an approved, documented BYOD exception with appropriate authentication, access restrictions, and separation of company data.

3.7 Monitoring and privacy

Company systems may log authentication, administrative actions, security events, device posture, network activity, and use of company services for security, support, compliance, and incident investigation. Monitoring must be proportionate to the stated business purpose, access to logs must be restricted, and any employee notice or consultation required by applicable law must be completed before monitoring begins. This policy does not authorise indiscriminate access to personal accounts or personal content.

4. Responsibilities

- **All users:** follow this policy, protect data and credentials, complete training, and report suspected incidents promptly.
- **Managers:** ensure staff understand applicable requirements and request access only for a justified business need.
- **IT Administrator:** maintain endpoint and identity baselines, document deviations, and disable unauthorised configurations where appropriate.
- **GRC Lead:** own the policy, track acknowledgements and exceptions, and coordinate periodic review.
- **Data owners:** approve external sharing and use of sensitive information where this policy requires owner approval.

5. Reporting, exceptions, and violations

Suspected phishing, malware, data exposure, lost devices, unauthorised access, accidental disclosure, or policy bypass must be reported immediately using #security-incident in the company Slack workspace or security@cyberdyne.example. Do not put passwords, tokens, or unredacted sensitive data in the initial report. Follow the Incident Reporting & Response Policy.

Exceptions require a documented business reason, affected systems/data, risk assessment, compensating controls, accountable owner, expiry date, and approval by the system owner plus the GRC Lead. Exceptions expire after 180 days at most unless re-approved. No exception can override applicable law or a binding customer/contractual obligation. See templates/policy-exception-request.md.

Violations may result in access restriction, retraining, formal HR action, or contract remedies, subject to applicable law and company procedures. Good-faith reporting is encouraged, and retaliation for raising a concern is prohibited.

6. Compliance checks and review

At least quarterly, the IT Administrator should review endpoint-management coverage, encryption status, endpoint-protection status, and overdue critical updates. At least annually, the GRC Lead should review

training completion, policy acknowledgements, incident trends, exception records, and changes in the technology stack. Findings must be tracked to closure with an owner and due date.

7. References

- NIST Cybersecurity Framework (CSF) 2.0
- CIS Critical Security Controls v8.1

Identity, Password & Authentication Standard

Policy ID: CS-GRC-STD-02
Owner: IT Administrator, with GRC oversight
Applies to: Workforce identities, privileged identities, and non-human/service identities
Issue date: September 2026
Version/status: 1.0 / Portfolio draft; simulated approval required
Review cadence: At least annually and after significant identity-platform changes
Related documents: Acceptable Use Policy; Access Control Policy; Incident Reporting & Response Policy

Portfolio status: Proposed standard for a fictional company, not an implemented or audited control environment.

1. Purpose and scope

Define minimum requirements for authenticating users and services accessing Google Workspace, Slack, GitHub, AWS, company laptops, production systems, and other company-approved services. Authentication strength must be proportionate to the value of the account and the impact of compromise.

2. Identity lifecycle and account ownership

- Every workforce user must have a unique, individually attributable account. Shared human accounts are prohibited.
- Identity creation, role changes, suspension, recovery, and deletion must follow the Access Control Policy and be linked to an approved request or HR event.
- Company-managed identity services and organisation-owned application tenants must be used where available. Personal identities must not own critical company repositories, cloud resources, or integrations.
- Non-human identities must have a named owner, a defined purpose, minimum permissions, documented credential storage, and a review date.

3. Multi-factor authentication

- MFA is mandatory for all workforce accounts in Google Workspace, Slack, GitHub, AWS, remote access, and other services that support it.
- Phishing-resistant MFA, such as FIDO2/WebAuthn security keys or passkeys, is required for privileged administrators and production-capable accounts where supported. If unavailable, use the strongest supported MFA method and document a time-bound remediation plan.
- SMS or voice one-time codes must not be the preferred method for privileged access. Their use requires documented justification where stronger methods are unavailable.
- MFA recovery methods must be protected to the same standard as the primary account. Recovery codes must be stored in an approved password manager or another approved secure location, never in source code or shared notes.
- MFA enrollment and recovery events should be logged. Unexpected MFA prompts, device enrollment notices, or authentication fatigue prompts must be reported as potential incidents.

4. Password and passphrase requirements

- Use a unique password or passphrase for every company account. Do not reuse personal passwords for business services.

- Use the company-approved password manager to generate and store passwords. Passwords must not be shared, emailed, pasted into tickets, or stored in plaintext files.
- Where a password is user-created, use a long password or passphrase; the system configuration should support at least 15 characters where passwords are the sole authentication factor and must not impose arbitrary complexity rules that encourage predictable substitutions. If MFA is always required, the company may configure a lower minimum only after a documented risk review and must still support long passwords.
- Block known-compromised or commonly used passwords where the identity provider supports this capability. Do not require routine calendar-based password changes solely as a ritual; require immediate change when compromise is suspected or confirmed, when a credential is exposed, or when a service provider mandates it for a documented reason.
- Password reset flows must verify the requester using approved recovery controls. Help-desk staff must never ask a user to reveal their current password or MFA code.

5. Privileged and high-impact accounts

- Separate everyday user activity from administrative activity where supported. Privileged identities must not be used for routine web browsing, email, or general collaboration.
- Grant administrative access to the minimum number of named personnel required to perform the function. Require documented approval from the system owner and IT Administrator.
- Use time-bound or just-in-time privilege elevation where technically feasible. Record the business purpose and retain relevant logs for privileged actions.
- Emergency or break-glass accounts must be tightly limited, protected by strong MFA, monitored, tested at least quarterly, and used only when normal administrative access is unavailable. Every use requires an incident or change record and post-use review within one business day.

6. Service accounts, API keys, and secrets

- Prefer short-lived credentials and workload identity over long-lived access keys wherever the platform supports them.
- Store secrets in an approved password manager or secrets manager with access limited to named maintainers. Do not hard-code secrets in repositories, images, build logs, environment files committed to version control, or tickets.
- Assign each service identity one documented owner and business purpose. Grant only permissions needed for its specific function; prohibit interactive login unless technically necessary and specifically approved.
- Review service identities and long-lived tokens at least quarterly. Rotate credentials on suspected exposure, ownership change, privilege change, or provider requirement. Where short-lived credentials are not available, document an expiry or rotation interval based on risk, with 180 days as the maximum default for static secrets absent an approved compensating design.
- Revoke tokens, keys, OAuth grants, SSH keys, and app passwords when no longer needed or when the owner leaves or changes roles. Secret exposure must be treated as a security incident, even if the secret is later deleted from the visible file.

7. Authentication logging and monitoring

The IT Administrator should enable available logging for sign-ins, MFA changes, password resets, failed login bursts, new OAuth grants, privileged actions, key creation, and account recovery. Alert thresholds should be tuned to reduce alert fatigue without suppressing meaningful high-risk behaviour. Log access must be restricted, and changes to logging configuration must be recorded.

8. Exceptions and enforcement

An exception must identify the affected service and users, the reason stronger authentication is unavailable, exposure duration, compensating measures, accountable owner, approval, and expiry. Exceptions involving privileged access require explicit executive sponsor acceptance if material residual risk remains after GRC review. Review all active exceptions at least monthly; each exception expires within 180 days unless re-approved.

9. Validation evidence

Expected evidence includes MFA-coverage exports, password-manager deployment records, privileged group membership, authentication configuration screenshots or exports, service-account inventory, secret-scanning results, exception approvals, and quarterly review tickets. Store evidence in an access-restricted company location and redact secrets and unnecessary personal data.

10. References

- NIST SP 800-63B-4: Digital Identity Guidelines - Authentication and Authenticator Management
- NIST CSF 2.0
- CIS Critical Security Controls v8.1

Access Control & Joiner-Mover-Leaver Policy

Policy ID: CS-GRC-POL-03
Owner: IT Administrator, with GRC oversight
Applies to: Workforce users, contractors, vendors, administrators, and service identities
Issue date: September 2026
Version/status: 1.0 / Portfolio draft; simulated approval required
Review cadence: At least annually; access reviews at the cadences below
Related documents: Identity, Password & Authentication Standard; Data Classification & Handling Policy; Incident Reporting & Response Policy

Portfolio status: Proposed policy for a fictional 50-person SaaS company. Approval and actual technical implementation have not occurred.

1. Purpose

Ensure access to applications, repositories, cloud environments, customer data, and corporate devices is authorised, appropriate to a person's role, time-bound where possible, and removed promptly when no longer required.

2. Core principles

- **Least privilege:** grant only the minimum access required for assigned duties.
- **Need to know:** access to Confidential and Restricted information requires a defined business need.
- **Named accountability:** each human account must map to one person; shared human accounts are prohibited.
- **Approval before access:** the request and approval must be recorded before routine access is provisioned.
- **Separation of duties:** requesters must not approve their own access. High-impact access requires a system owner or delegated approver independent of the requester.
- **Time-bounded access:** contractor, vendor, incident-response, and temporary project access must have an expiry date.

3. Access request and provisioning

1. The manager or accountable sponsor submits an access request using templates/access-request.md or the company's ticket system.
2. The request states the user's identity, role, business justification, systems/groups/permissions, data sensitivity, start date, expiry date (if temporary), and manager or sponsor.
3. The system owner approves the requested level of access. Requests for AWS production, customer-data export, organisation-owner privileges, repository administration, or other high-impact permissions also require IT Administrator review.
4. IT provisions access through organisation-managed identities and groups, records completion, and links the request to the approved role or group.
5. The requester and manager are notified. Access is not considered approved merely because it was technically possible to grant.

Routine access should be provisioned within two business days after a complete approval. Production or administrative access must be individually attributable and should use separate privileged accounts where

supported. Emergency access may be granted under the break-glass process, but must be recorded and reviewed by the next business day.

4. Joiners

People Ops must notify IT and the hiring manager before the user's start date. Access is provisioned only after an authorised start is confirmed and required onboarding checks are complete. The baseline should include a unique company identity, mandatory MFA, approved password manager access, least-privilege collaboration access, device-management enrollment, endpoint protection, and policy/security-training acknowledgement. Production access is not part of the default onboarding bundle.

5. Movers and role changes

Managers must submit role changes before or promptly when responsibilities change. IT must compare new permissions to existing permissions, remove access no longer needed, and grant new access only after required approval. Do not accumulate permissions as a user moves between roles. Temporary project privileges must expire automatically where supported or be tracked with a specific review date.

6. Leavers and urgent termination

People Ops or the authorised manager must notify IT of a termination or contract end as soon as the timing is confirmed. At the effective termination time, IT must disable interactive sign-in for company identities and revoke active sessions where supported. The operational target is to complete disabling the primary identity, privileged access, VPN/remote access, and access to Google Workspace, Slack, GitHub, and AWS within 1 hour of the effective time; for involuntary or high-risk departures, coordinate a synchronised disablement at the effective time. Where a tool cannot be disabled centrally, remove access directly and record the result.

The offboarding checklist must also cover: revocation of MFA authenticators and recovery options; removal of group memberships and app assignments; revocation of tokens, app passwords, OAuth grants, SSH keys, cloud access keys and personal access tokens; transfer of repository, document, calendar, and service ownership; recovery of company devices and badges; preservation of business records; and confirmation from relevant system owners. Do not delete the person's work product or logs as a substitute for transferring ownership.

7. Access reviews

- Review privileged access, AWS production access, organization-owner/admin roles, customer-data export permissions, and break-glass accounts at least quarterly.
- Review all other workforce access at least every six months.
- Review contractor/vendor access monthly and at the end of the engagement.
- The reviewer must be the manager or system/data owner, not the sole subject of the review. The reviewer records each account as retained, modified, or revoked, with rationale and completion date.
- IT tracks removals and modifications to completion, with a target of five business days for standard review actions and immediate handling for clearly unauthorised or high-risk access.
- Evidence must include the population reviewed, reviewer, review date, decisions, exceptions, and closure tickets. A screenshot of a few accounts without a population/export is insufficient evidence of a complete review.

8. Vendors and third parties

Third-party access requires a named internal sponsor, an approved business purpose, minimum permissions, MFA where supported, contractual confidentiality/security terms appropriate to the engagement, and a

defined expiry date. Prefer separate accounts or federated access. Vendors must not share accounts or retain access after the engagement ends. Access to customer or Restricted data requires data-owner approval and a documented purpose.

9. Service and automation identities

Each service identity must have an owner, function, approved permissions, secure credential storage, rotation/revocation plan, and review cadence. Service identities must not be used as substitutes for human attribution. Remove obsolete identities and disable unused keys or tokens. See the Identity, Password & Authentication Standard for credential requirements.

10. Exceptions, evidence, and review

Exceptions follow the policy-exception process. They must specify the identity, access, systems, reason, compensating controls, accountable risk owner, approval, and expiry. Access-control evidence must be protected from broad access and retained under the company's records schedule; the project default is at least 12 months unless law, contract, incident preservation, or an approved schedule requires otherwise.

At least annually, the GRC Lead should analyse access-review completion, late offboarding actions, stale accounts, privilege accumulation, and overdue exceptions. Recurring failures require a tracked corrective-action plan.

11. References

- NIST CSF 2.0
- CIS Critical Security Controls v8.1

Data Classification & Handling Policy

Policy ID: CS-GRC-POL-04
Owner: GRC Lead; individual data owners remain accountable for assigned datasets
Applies to: All company, customer, workforce, product, and operational information handled by the company
Issue date: September 2026
Version/status: 1.0 / Portfolio draft; simulated approval required
Review cadence: At least annually and when data uses or obligations materially change
Related documents: Acceptable Use Policy; Access Control Policy; Incident Reporting & Response Policy

Portfolio status: Classification categories and handling rules are proposed for a fictional company. They are not a legal classification scheme and do not establish compliance with any specific privacy regulation.

1. Purpose

Provide a consistent way to classify information by sensitivity and define how it may be collected, accessed, stored, shared, transmitted, retained, and disposed of. Classification should guide controls without implying that labels alone make data secure.

2. Roles and default classification

The data owner assigns or confirms a classification, approves permitted uses and sharing, and sets retention based on business needs, customer contracts, and applicable obligations. Anyone creating or receiving information must protect it according to its known classification. If uncertain, treat information as Confidential until the data owner clarifies it. Customer production data defaults to Confidential; authentication secrets, private keys, and high-impact production credentials are Restricted.

3. Classification levels

Public

Definition and examples: Information approved for unrestricted public release, such as published marketing material or public documentation.

Minimum handling: The data owner or Communications approver must authorise publication. Confirm the material contains no secrets, personal data, customer content, internal URLs, or other embedded sensitive information.

Internal

Definition and examples: Routine company information not intended for public release, such as internal meeting notes, general procedures, non-sensitive project plans, and workforce announcements.

Minimum handling: Store in approved company systems. Share with workforce members who need it. External sharing requires an accountable business owner and a legitimate purpose.

Confidential

Definition and examples: Information whose unauthorised disclosure could harm customers, employees, or the company, such as customer contact details, non-public business plans, contracts, support tickets, non-public source code, and ordinary production logs that may contain identifiers.

Minimum handling: Limit access by role and need-to-know. Use approved company storage and encrypted transmission. External sharing requires data-owner approval, recipient verification, least-privilege access, and expiry where supported. Avoid local copies and use masking for testing where feasible.

Restricted

Definition and examples: Highest-sensitivity information whose disclosure or alteration could create serious harm, including passwords, MFA recovery codes, private keys, secrets, sensitive authentication material, production credentials, and high-impact customer datasets or exports designated by the data owner.

Minimum handling: Access only to explicitly authorised personnel. Store in an approved secrets manager or approved restricted-access repository. Encrypt in transit and at rest. Log privileged access where technically feasible. Do not place in public or personal services, source code, general chat, public issue trackers, or unapproved AI tools. External transfer requires documented business need, data-owner approval, recipient validation, and an approved secure transfer method.

Classification is based on sensitivity and potential impact, not merely file format or storage location. Datasets may contain information in multiple classes; apply the highest relevant classification unless fields are reliably segregated and the data owner approves a different treatment.

4. Collection, storage, and access

- Collect and retain only information required for a defined business purpose. Data owners should review unnecessary collection and long-lived copies.
- Store company information only in approved organisation-managed Google Workspace, Slack, GitHub, AWS, or other services approved for the relevant data class.
- Access must follow the Access Control Policy. Grant data access by named role or group, avoid broad links and public buckets, and review access when a user's role changes.
- Encrypt Confidential and Restricted information in transit using current secure transport protocols supported by the platform. Use provider or platform encryption at rest as a baseline; Restricted data must use approved secrets management or storage controls appropriate to its risk.
- Do not copy production customer data into development, demonstration, training, or personal environments unless a data owner approves a documented need and suitable minimization, masking, access restriction, and deletion plan.
- Before uploading data to a repository, issue tracker, chat, analytics tool, or AI service, confirm the destination is approved for that classification.

5. Sharing and transfer

Before external sharing, the sender must verify the recipient's identity and authority, confirm business need, select the minimum necessary dataset, use an approved transfer method, and set access restrictions or expiry dates where supported. The data owner approves external sharing of Confidential and all Restricted data. Public links, anonymous downloads, personal email, consumer file-sharing, and unapproved external AI tools are prohibited for Confidential and Restricted information.

For exports, include the purpose, requesting party, approving data owner, fields included, transfer method, recipient, and planned deletion/retention date in the ticket or record. Use redaction, aggregation, synthetic data, or pseudonymization when it meets the task's needs. Pseudonymized information may remain personal or sensitive data under applicable law and must not automatically be treated as anonymous.

6. Retention and secure disposal

Each data owner must document retention and deletion requirements based on business use, customer commitments, and applicable legal obligations. When no specific schedule has been approved, the owner must avoid indefinite retention and propose a schedule for GRC review. Deletion must cover active copies and, where feasible, replicas and exports under the company's control. Backups may age out under the approved

backup schedule; do not promise immediate physical erasure from immutable backups unless the technical design supports it. Devices and media must be securely wiped or destroyed before reuse, return, or disposal using a method appropriate to the media and data sensitivity.

7. Data incidents

Accidental disclosure, wrong-recipient sharing, public repository exposure, lost media, suspicious downloads, suspected exfiltration, and unauthorised access must be reported immediately under the Incident Reporting & Response Policy. Do not silently delete, overwrite, or alter the only evidence of the event. Preserve context and share the location of the exposure with authorised responders without redistributing the sensitive content.

8. Review and evidence

Evidence may include a data inventory, approved classifications, repository visibility settings, external sharing logs, storage policies, access-control exports, retention/deletion records, and approved data-transfer tickets. GRC should sample high-risk datasets and review externally shared Confidential/Restricted data at least quarterly, where platform evidence supports the review.

9. References

- NIST CSF 2.0
- CIS Critical Security Controls v8.1

Security Incident Reporting & Response Policy

Policy ID: CS-GRC-POL-05
Owner: Incident Response Lead (simulated role), with GRC coordination
Applies to: All workforce members, contractors, systems, cloud services, devices, and company/customer data
Issue date: September 2026
Version / status: 1.0 / Portfolio draft; simulated approval required
Review cadence: At least annually; after significant incidents, tabletop exercises, or material system changes
Related documents: All policies in this pack; templates/incident-intake.md

Portfolio status: This is a proposed response policy and illustrative service target, not evidence that a staffed 24/7 response function exists. A real organisation must confirm contacts, staffing, escalation paths, legal obligations, and provider capabilities before approval.

1. Purpose

Establish a consistent way to report, triage, investigate, contain, eradicate, recover from, and learn from suspected security incidents. Fast, good-faith reporting is more important than proving an incident before escalation.

2. What to report

Report immediately when you suspect or observe any of the following:

- A lost or stolen company laptop, phone, token, security key, or storage device.
- A phishing message, suspicious login prompt, unexpected MFA request, malware alert, or unusual account recovery event.
- Unauthorized account access, unexplained privilege changes, suspicious OAuth grants, exposed access keys, secrets in a repository, or unexpected administrator activity.
- Customer or company data sent to the wrong recipient, made publicly accessible, downloaded unexpectedly, or disclosed through an unapproved service.
- Unexpected production changes, unusual cloud behaviour, service disruption that may be security-related, or evidence of tampering.
- A third-party security notification, vulnerability exploitation, suspected insider misuse, or any event that could affect confidentiality, integrity, or availability.

Near misses and mistaken clicks should also be reported. Staff must not delay a report while trying to investigate independently.

3. How to report

Use the company Slack channel #security-incident or email security@cyberdyne.example. For a suspected active compromise, use the fastest available route to contact the Incident Response Lead or IT Administrator as well. If Slack or email may be compromised or unavailable, use a separately verified contact path established during implementation.

Include, if known: reporter and safe contact method; time first noticed and time zone; affected account/device/system; what happened; relevant message, alert, ticket, or log location; potential data affected; actions already taken; and whether the activity is continuing. Do not include passwords, MFA codes, private keys, access tokens, unnecessary personal data, or full copies of sensitive records in the initial message. Use a secure evidence location and share access with responders only.

4. Severity and initial response targets

These are proposed internal planning targets for the simulated 50-person company, not contractual SLAs or guarantees. The Incident Response Lead must validate staffing and tool coverage before these targets are adopted.

SEV-1 Critical

Illustrative trigger: Confirmed or strongly suspected production compromise, active unauthorized access to Restricted/customer data, broad credential compromise, destructive activity, or material service outage caused by malicious activity.

Acknowledgement / triage target: Acknowledge within 15 minutes during the designated on-call coverage period; immediately escalate to the executive sponsor and relevant system owner.

Minimum response expectation: Assign an incident commander, establish a timeline, preserve evidence, prioritize containment, and assess customer/legal notification needs. If 24/7 coverage is not staffed, document the real coverage gap and escalation arrangement.

SEV-2 High

Illustrative trigger: Compromised privileged account, active malware on a device with sensitive access, unauthorized repository/cloud access, or credible suspected data exfiltration without confirmed broad impact.

Acknowledgement / triage target: Acknowledge within 1 hour during staffed coverage.

Minimum response expectation: Assign an owner, investigate scope, implement proportionate containment, and provide regular updates to affected stakeholders.

SEV-3 Moderate

Illustrative trigger: Suspicious activity requiring investigation but with no confirmed material compromise, a limited policy breach, or an isolated endpoint alert.

Acknowledgement/triage target: Acknowledge within 1 business day.

Minimum response expectation: Triage, gather evidence, decide whether escalation is needed, and document closure or further action.

SEV-4 Low / Informational

Illustrative trigger: Benign security question, near miss, blocked event, or low-risk weakness that does not require incident command.

Acknowledgement / triage target: Acknowledge within 3 business days.

Minimum response expectation: Record, route to the appropriate owner, and use for awareness or backlog improvement as appropriate.

Any responder may raise severity when new evidence increases potential impact. Reduce severity only with a documented rationale from the Incident Response Lead. Applicable legal, regulatory, contractual, cyber-insurance, or law-enforcement deadlines supersede these internal targets.

5. Response lifecycle

5.1 Record and triage

Create an incident record with a unique ID, timestamps in UTC where practical, reporter, affected assets, severity, assigned incident commander, initial facts, open questions, and links to evidence. Separate verified facts from assumptions or hypotheses. Record source and time of each significant observation.

5.2 Contain

Choose containment that reduces harm while protecting evidence and business continuity. Examples include disabling a compromised identity, revoking sessions and tokens, isolating an endpoint, restricting a public repository or storage bucket, applying a cloud permission block, or temporarily disabling an integration. Where feasible, record who authorized and performed each action, the time, expected side effects, and result. Do not perform actions outside your authority; escalate when a high-impact change is required.

5.3 Preserve evidence

Preserve relevant logs, alerts, messages, file hashes, access records, cloud audit events, and device details. Use read-only exports or approved acquisition procedures where feasible. Maintain a simple chain-of-custody record for evidence intended for legal, disciplinary, contractual, or forensic use: evidence ID, description, source, collector, collection time, method/tool and version if known, hash where appropriate, storage location, access/transfers, and integrity verification. Restrict access to evidence; do not circulate sensitive artefacts in general chat.

Do not wipe, reimage, delete, or power off a potentially compromised device unless an authorized responder determines that action is necessary to contain active harm or protect people. Do not run unapproved tools or conduct invasive investigation without authorisation.

5.4 Eradicate and recover

Remove the cause where understood, rotate/revoke exposed credentials, remediate exploited weaknesses, rebuild or restore affected systems using trusted procedures, and validate that access controls and monitoring are functioning before returning a system to normal operation. The system owner approves service restoration with the Incident Response Lead. Record residual risk and any temporary compensating controls.

5.5 Communicate and close

The Incident Response Lead coordinates status updates with the executive sponsor, IT, affected system/data owners, People Ops, and legal/privacy counsel when available and appropriate. Only an authorized spokesperson may make external customer, regulator, press, or public statements. Do not speculate or make commitments beyond verified facts. Legal/privacy counsel and responsible business leaders determine whether and when notifications are required under applicable law and contracts.

Close the incident record only when scope and impact have been documented to a reasonable level, containment and recovery actions have owners and status, required notifications have been assessed, evidence is preserved, and follow-up tasks are assigned. Material incidents require a lessons-learned review within 10 business days of containment, unless the Incident Response Lead documents why more time is needed.

6. Roles and decision authority

- **Reporter:** reports quickly, preserves context, and avoids unauthorized investigation.
- **Incident Response Lead / Incident Commander:** owns triage, severity, coordination, timeline, containment recommendations, and closure readiness.
- **IT Administrator / system owner:** executes approved technical actions and validates recovery.
- **GRC Lead:** maintains process documentation, evidence tracking, risk register updates, policy exceptions, metrics, and corrective actions.
- **Executive sponsor:** makes material business-risk decisions and provides resources; accepts residual risk only where authorised.
- **Legal/privacy counsel and authorised communications lead:** assess legal/contractual notifications and approve external messaging in coordination with business leadership.

- **People Ops:** supports employee communications and HR processes as appropriate.

7. Retaliation, confidentiality, and reporting hygiene

Good-faith reporting is encouraged even when an employee has clicked a link or made a mistake. Retaliation for raising a security concern is prohibited. Incident details must be shared only with people who need them to respond. Do not post incident evidence publicly or discuss customer-impact claims outside the authorised response group.

8. Testing and continuous improvement

At least annually, conduct a tabletop exercise covering a realistic scenario such as compromised Google Workspace credentials, leaked GitHub token, exposed AWS storage, or lost laptop with a valid session. Record participants, scenario, decisions, timing, gaps, owner, and due date. Track lessons learned and repeat tests after major changes. Review incident metrics quarterly, including time to acknowledge, time to contain, incidents by root cause, recurring vulnerabilities, reporting delays, and overdue corrective actions.

9. References

- NIST CSF 2.0
- CIS Critical Security Controls v8.1
- NIST SP 800-63B-4 for identity-related incident context

Appendix A - Framework References and Interpretation

This policy pack uses the references below as design inputs, not as evidence of compliance:

- NIST Cybersecurity Framework 2.0: https://doi.org/10.6028/NIST.CSWP.29
- NIST SP 800-63B-4, Authentication and Authenticator Management: https://doi.org/10.6028/NIST.SP.800-63b-4
- CIS Critical Security Controls v8.1: https://www.cisecurity.org/controls/v8-1
- NIST SP 1299, CSF 2.0 Resource and Overview Guide: https://doi.org/10.6028/NIST.SP.1299

The separate docs/control-mapping.csv maps the policy requirements to high-level NIST CSF 2.0 categories and CIS Controls v8.1 control areas. These are indicative mappings that must be checked against exact framework wording, system scope, and an organisation's selected target profile before formal use.

Appendix B - Governance and Implementation Companion

The GitHub repository contains additional operational materials not reproduced in full in this compiled policy pack:

- docs/implementation-roadmap.md - proposed 30/60/90-day rollout.
- docs/risk-register.csv - illustrative risk scenarios, treatments, and target residual scores.
- docs/evidence-register.csv - expected evidence, owner, cadence, and handling notes.
- docs/audit-test-plan.md - repeatable tests and pass/fail criteria.
- docs/roles-and-responsibilities.md - proposed RACI.
- docs/policy-exception-register-template.csv and templates/ - working forms.

The residual scores are targets and have not been validated through implementation or testing. One recovery/backup risk is intentionally left open to show the boundary of a five-policy starter pack.

Appendix C - Portfolio Disclaimer

This pack was prepared by Aditi Rajendra Katare in September 2026 as an independent portfolio simulation. No actual Cyberdyne Systems environment was accessed or assessed. There is no claim of operational deployment, approval, audit completion, legal sufficiency, or conformance certification. In a real organisation, the policy owner and qualified reviewers must validate requirements against business context, applicable laws, privacy and employment requirements, customer agreements, service capabilities, staffing, and risk appetite.